

# Audit de sécurité physique : compromission d'un compte local Windows

## Table des matières

|                                        |   |
|----------------------------------------|---|
| Introduction : .....                   | 2 |
| L'environnement de test.....           | 2 |
| Le déroulé de l'attaque .....          | 2 |
| Conclusions et verdict .....           | 5 |
| Comment s'en protéger vraiment ? ..... | 5 |

## Introduction :

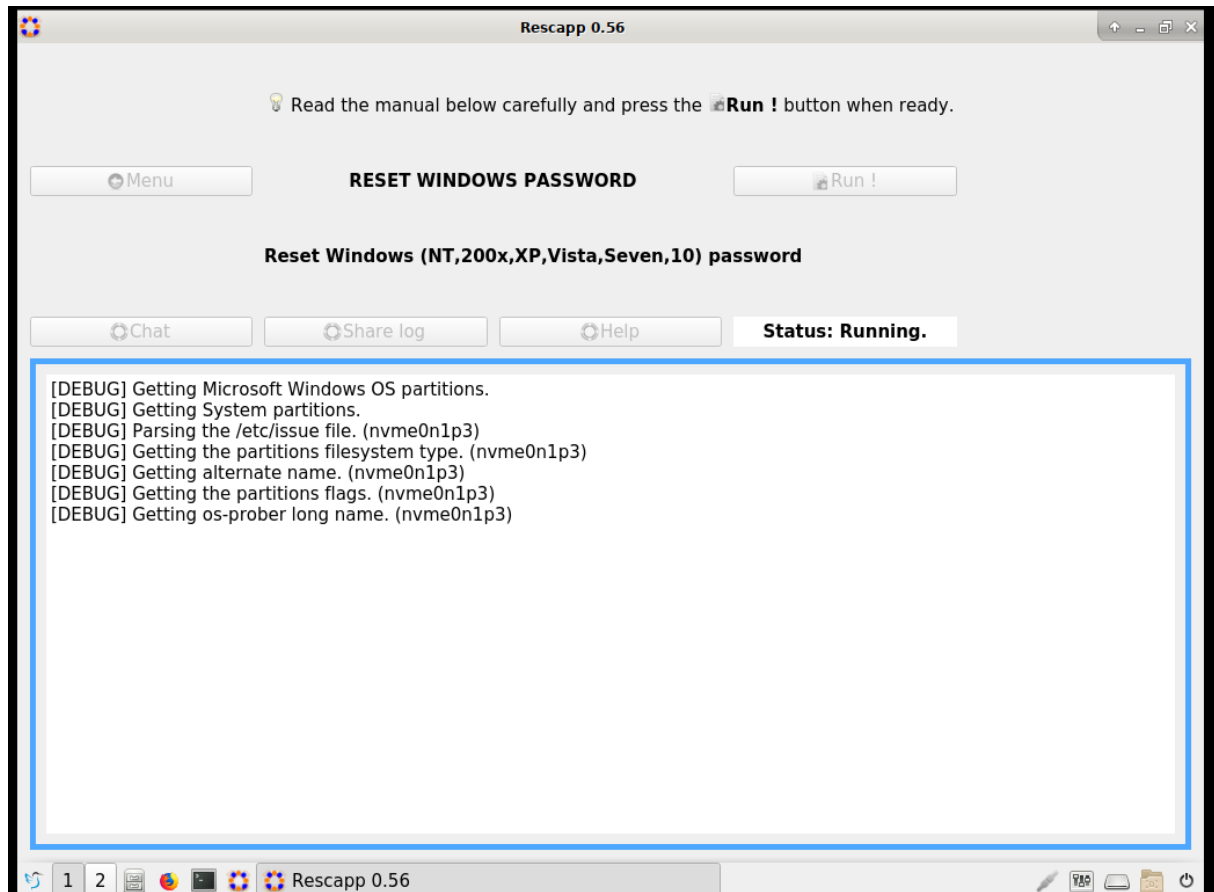
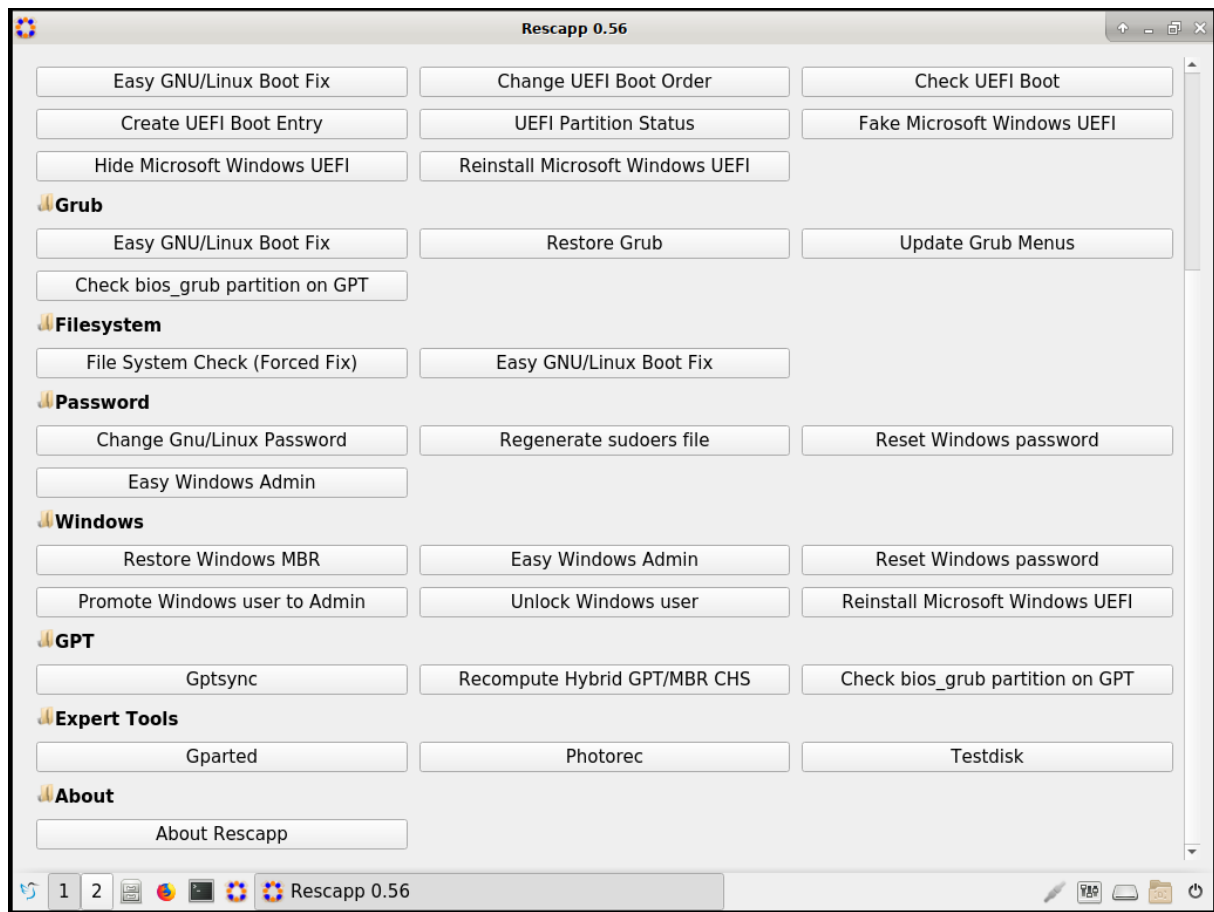
Pour démontrer concrètement l'importance de la sécurité physique en entreprise, nous avons récemment simulé une attaque ciblée. L'idée de cette intervention, réalisée dans un cadre purement pédagogique, était de se glisser dans la peau d'un individu malveillant face à une machine laissée sans surveillance. L'objectif : tester la réelle robustesse d'un mot de passe de session Windows classique.

## L'environnement de test

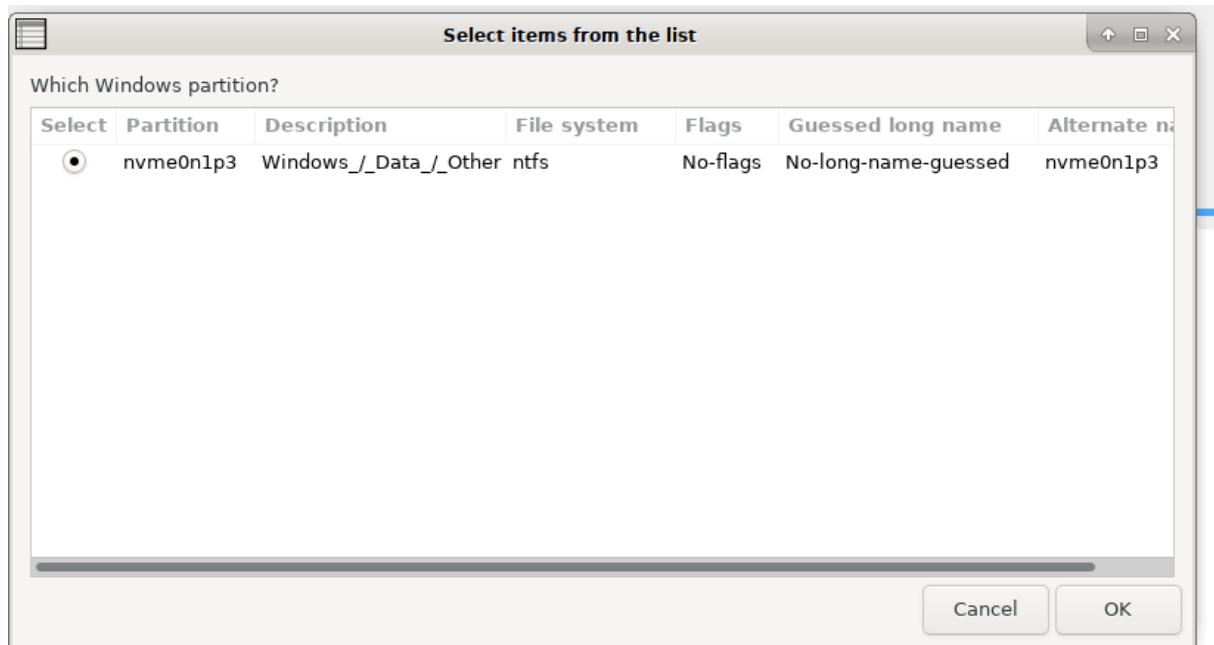
Le scénario s'est déroulé sur une machine virtuelle tournant sous Windows 10 Pro. Nous avons configuré un compte administrateur local verrouillé par mot de passe, avec un faux fichier contenant des données sensibles placé bien en évidence sur le bureau. Côté attaque, l'outil privilégié a été une image ISO de Rescatux. Il s'agit d'une distribution Linux très efficace, habituellement pensée pour le dépannage informatique, mais qui se révèle redoutable pour contourner les protections logicielles.

## Le déroulé de l'attaque

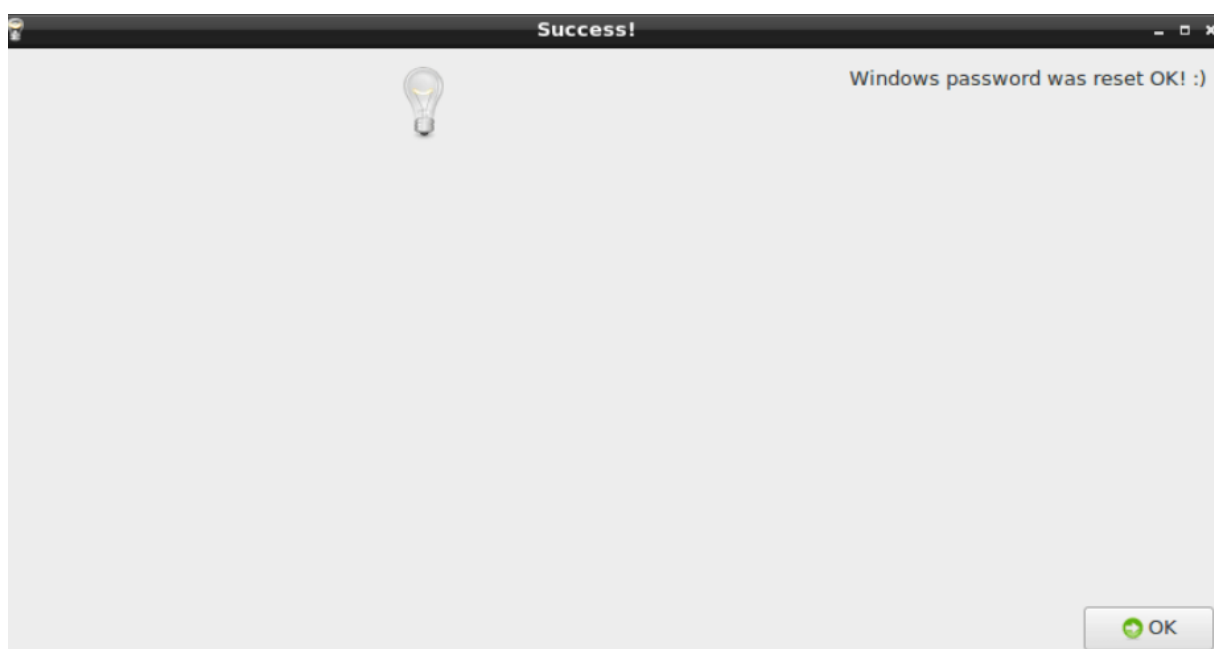
Plutôt que d'essayer de deviner ou de forcer le mot de passe, la méthode la plus rapide consiste tout simplement à l'ignorer. Pour y parvenir, l'ordinateur n'a pas démarré sur son disque dur Windows, mais a été amorcé directement sur le Live-CD Rescatux. Cette technique permet de court-circuiter totalement le système d'exploitation cible et ses barrières de sécurité.



Une fois sur l'interface Linux, la suite est d'une grande simplicité. Il suffit de monter la partition principale pour pouvoir naviguer librement dans l'arborescence du disque. Le fameux fichier sensible devient alors totalement lisible et copiable vers un support externe, sans jamais avoir eu besoin de s'authentifier au préalable.



L'intrusion ne s'est pas arrêtée à la simple lecture. Les outils intégrés à Rescatux permettent d'interagir directement avec la base de données SAM de Windows, qui est le cœur de la gestion des identifiants locaux. En quelques clics sur l'interface, le mot de passe administrateur a été purement et simplement effacé. Au redémarrage suivant, la machine s'est lancée normalement et la session s'est ouverte d'elle-même, livrant un contrôle absolu sur le système.



## Conclusions et verdict

Cette expérimentation vient confirmer une règle d'or trop souvent sous-estimée : un accès physique non sécurisé équivaut à une machine totalement compromise. Le mot de passe d'ouverture de session ne protège pas les données. Ce n'est qu'un simple contrôle d'accès logiciel qu'il est facile d'enjamber à l'aide d'un support externe en l'espace de quelques minutes.

## Comment s'en protéger vraiment ?

Pour se prémunir efficacement contre cette menace, il est impératif de superposer les couches de sécurité selon le principe de la défense en profondeur.

La mesure la plus critique reste le chiffrement intégral du disque dur via une solution comme BitLocker. C'est l'ultime rempart. Même si un attaquant parvient à démarrer sur un système externe, le contenu de la partition restera un amas de données illisibles sans la clé de déchiffrement. Toute exfiltration ou modification de la base SAM devient alors techniquement impossible.

Ensuite, il faut impérativement bloquer les portes d'entrée matérielles. Cela passe par la configuration d'un mot de passe robuste au niveau du BIOS ou de l'UEFI, couplée à la désactivation stricte de l'amorçage sur clé USB ou lecteur CD.

Enfin, la sécurité physique matérielle ne doit pas être négligée. L'utilisation de câbles antivol de type Kensington et la restriction de l'accès aux locaux constituent les premières barrières de bon sens pour empêcher qu'un individu ne manipule l'ordinateur à l'abri des regards.